

Task 1 - Web Security Assessment Report

Site used: <https://securityheaders.com/>

Target: <https://www.rbi.org.in/>

Assessment Type: Passive (Read-Only Analysis)

Date: 29 April 2026

1. Executive Summary

A read-only security assessment was conducted on the target web application to evaluate its external security posture. The analysis focused on HTTP security headers, visible configurations, and general exposure indicators without performing intrusive testing.

The website received a **security grade of “C”**, indicating a **moderate security posture** with foundational protections in place but notable gaps that could expose the application to client-side attacks such as Cross-Site Scripting (XSS) and data leakage.

While essential headers such as **X-Frame-Options**, **X-Content-Type-Options**, and **Strict-Transport-Security (HSTS)** are correctly implemented, the absence of key modern security headers significantly weakens defense-in-depth mechanisms.

The screenshot displays the Security Headers report from securityheaders.com for the target URL <https://www.rbi.org.in/>. The report shows a security grade of 'C'. The headers section lists the following status: X-Frame-Options (checked), X-Content-Type-Options (checked), Strict-Transport-Security (checked), Content-Security-Policy (missing), Referrer-Policy (missing), and Permissions-Policy (missing). The 'Missing Headers' section provides detailed descriptions for the missing headers: Content-Security-Policy, Referrer-Policy, and Permissions-Policy.

Header	Status
X-Frame-Options	Present
X-Content-Type-Options	Present
Strict-Transport-Security	Present
Content-Security-Policy	Missing
Referrer-Policy	Missing
Permissions-Policy	Missing

Missing Headers

- Content-Security-Policy**: Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
- Referrer-Policy**: Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
- Permissions-Policy**: Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

2. Scope and Methodology

Scope

- Public-facing web application
- Passive inspection only (no exploitation or active probing)

Methodology

- Analysis of HTTP response headers
- Identification of missing or misconfigured security controls
- Visual inspection of scan results
- Risk classification based on industry best practices (OWASP)

3. Observations and Findings

3.1 Network and Service Exposure

- The application is accessible over **HTTPS**, indicating encrypted communication.
- No additional exposed services (e.g., APIs, admin panels, open ports) were visible from the provided scan.

Assessment:

- External attack surface appears **limited at the network level**.
- However, deeper scanning would be required to confirm hidden services.

3.2 Implemented Security Controls

The following headers are properly configured:

X-Frame-Options

- Protects against **clickjacking attacks** by preventing embedding in iframes.

X-Content-Type-Options

- Prevents **MIME-type sniffing**, reducing the risk of malicious file execution.

Strict-Transport-Security (HSTS)

- Enforces HTTPS usage, mitigating **man-in-the-middle (MITM) attacks**.

Assessment:

These controls demonstrate adherence to **baseline security practices** and provide essential protections.

3.3 Missing Security Headers

3.3.1 Content-Security-Policy (CSP)

Issue:

The absence of a CSP header means the browser does not restrict the sources from which scripts and other resources can be loaded.

Why It Matters:

Without CSP, attackers can inject malicious scripts via XSS vulnerabilities, leading to:

- Session hijacking
- Credential theft

Risk Level: High

3.3.2 Referrer-Policy

Issue:

The application does not define how much referrer information is shared during navigation.

Why It Matters:

Sensitive information embedded in URLs (e.g., tokens, session IDs) may be unintentionally exposed to third-party domains.

Risk Level: Medium

3.3.3 Permissions-Policy

Issue:

No restrictions are defined for browser features such as camera, microphone, or geolocation.

Why It Matters:

If combined with other vulnerabilities, attackers may exploit browser capabilities without explicit user awareness.

Risk Level: Low to Medium

3.4 Outdated Components

- No visible indicators of outdated software components were identified in the provided screenshot.

Assessment:

- Status remains **inconclusive**

- Requires deeper inspection (e.g., fingerprinting, dependency scanning)

4. Risk Classification Summary

Finding	Risk Level	Impact
Missing Content-Security-Policy	High	XSS, data theft, session hijacking
Missing Referrer-Policy	Medium	Information leakage
Missing Permissions-Policy	Low–Medium	Abuse of browser features

Raw Headers	
HTTP/2	200
date	Wed, 29 Apr 2026 13:04:59 GMT
content-type	text/html; charset=utf-8
vary	Accept-Encoding
cache-control	private
set-cookie	ASP.NET_SessionId=ewd42u4ikog5p1jkkbn40fe3; path=/; secure; HttpOnly; SameSite=Lax
set-cookie	IncPath=Includes1; expires=Thu, 29-Apr-2027 13:04:58 GMT; path=/; secure; HttpOnly
x-frame-options	SAMEORIGIN
x-xss-protection	1; mode=block
x-content-type-options	nosniff
set-cookie	cookie=IVfP+VRjgdLmFb+96RiFwD3VL7+qapVNMSeYJ5e29FX46nKQyVxabcG3Akp3dNEtVxQMhJn0rpUJA==; path=/; Httponly; Secure
strict-transport-security	max-age=16070400; includeSubDomains
set-cookie	f5_cspm=1234;
set-cookie	TS0178b498-012e6ca2ad207e1ba8368a6be4d876c50ed422a71663f52c4c834f4057485b30272c373a65b715defe8ec19e536b9c18e27b387234a04c96f6dfc55a905c0c557d2f3baaf2a6c44c4f852d0821c9f9c477ee529f27e2f246af850a06baa7ff218a38517a2739c85ebfd97b363c608741e692a27301; Path=/; Domain=www.rbi.org.in
set-cookie	ASLBAS=000342ea005d73145f10185e2bf90b3375a7f73c651346e21f9704193dee9b3edf51; Path=/; Secure; HttpOnly;
set-cookie	ASLBASACORS=000342ea005d73145f10185e2bf90b3375a7f73c651346e21f9704193dee9b3edf51; SameSite=none; Path=/; Secure; HttpOnly;
x-azure-ref	20260429T130458Z-15449bd8b96mm8x6hC1DUBs18w0000000mkq000000007r1a
x-cache	CONFIG_NOCACHE
content-encoding	gzip

5. Overall Risk Evaluation

The application demonstrates **partial compliance with security best practices**. While foundational controls are in place, the absence of modern security headers exposes the system to **client-side attack vectors**.

Overall Risk Rating:
Moderate Risk (Requires Remediation)

6. Recommendations and Remediation

6.1 Implement Content-Security-Policy (Priority: High)

Action:
 Define a strict policy to control resource loading.

Example Configuration:

Content-Security-Policy: default-src 'self'; script-src 'self' https://trusted.cdn.com;

Business Impact:

- Prevents unauthorized script execution
- Protects user data and sessions

6.2 Configure Referrer-Policy (Priority: Medium)**Action:**

Limit referrer data exposure.

Recommended Setting:

Referrer-Policy: strict-origin-when-cross-origin

Business Impact:

- Reduces risk of sensitive data leakage

6.3 Apply Permissions-Policy (Priority: Medium)**Action:**

Restrict access to browser features.

Example:

Permissions-Policy: camera=(), microphone=(), geolocation=()

Business Impact:

- Prevents misuse of device capabilities

6.4 Conduct Advanced Security Testing

To strengthen the overall security posture, the following are recommended:

- Vulnerability Assessment (VA)
- Penetration Testing (PT)
- API Security Testing
- Dependency and patch management review

7. Conclusion

The assessed web application demonstrates **basic security hygiene** but lacks critical modern protections that are essential in today's threat landscape. The absence of key headers—particularly Content-Security-Policy—introduces significant risk exposure.

Addressing these issues will:

- Enhance client-side security
- Reduce attack surface
- Improve compliance with industry standards (e.g., OWASP, NIST)

- Harini Prabhakaran